Payment Card Industry
Estándar de Seguridad de Datos

Cuestionario de Autoevaluación B-IP y Certificado de Conformidad

Para uso con el PCI DSS Versión 4.0.1

Fecha de Publicación: Octubre de 2024

DECLARACIONES: La versión en inglés del texto en este documento tal y como se encuentra en el sitio web de PCI SSC deberá considerarse, para todos los efectos, como la versión oficial de estos documentos y, si existe cualquier ambigüedad o inconsistencia entre este texto y el texto en inglés, el texto en inglés en dicha ubicación es el que prevalecerá.

Cambios en el Documento

Fecha	Versión PCI DSS	Revisión SAQ	Descripción
N/A	1.0		No utilizado.
N/A	2.0		No utilizado.
Febrero de 2014	3.0		Nuevo SAQ para abordar los requisitos aplicables a los comerciantes que procesan los datos de tarjetahabiente únicamente a través de dispositivos de punto de interacción autónomos y aprobados por la PTS con conexión IP al procesador de pagos. El contenido se alinea con los requisitos y procedimientos de prueba PCI DSS v3.0.
Abril de 2015	3.1		Actualizado para alinearse con PCI DSS v3.1. Para ver los detalles de cambios en PCI ver PCI DSS –*Resumen de Cambios de la Versión PCI DSS 3.0 a 3.1.*
Julio de 2015	3.1	1.1	Actualizado para eliminar las referencias a las "mejores prácticas" previas al 30 de junio de 2015.
Abril de 2016	3.2	1.0	Actualizado para alinearse con PCI DSS v3.2. Para ver los detalles de cambios en PCI DSS, ver PCI DSS - *Resumen de Cambios de la Versión 3.1 a 3.2.* Requisitos agregados de PCI DSS v3.2 Anexo A2.
Enero de 2017	3.2	1.1	Cambios de Documento Actualizados para aclarar los requisitos agregados en abril de 2016. Se Actualizó la Sección Antes de Empezar para aclarar el término «SCR» y la intención de los sistemas permitidos. Se añadió el Requisito 8.3.1 para alinearlo con el objetivo del Requisito 2.3. Se agregaron el Requisito 11.3.4 para verificar los controles de segmentación, si se utiliza la segmentación.
Junio de 2018	3.2.1	1.0	Actualizado para alinearse con PCI DSS v3.2.1. Para ver los detalles de cambios en PCI ver PCI DSS –*Resumen de Cambios de la Versión PCI DSS 3.2 a 3.2.1.*
Abril de 2022	4.0		Actualizado para alinearse con PCI DSS v4.0. Para ver los detalles de cambios en PCI ver PCI DSS –Resumen de Cambios de la Versión PCI DSS 3.2.1 a 4.0. Se ha reordenado, re-titulado y ampliado la información de la sección "Cómo Llenar el Cuestionario de Autoevaluación" (previamente titulada "Antes de Empezar"). Alineación del contenido de las Secciones 1 y 3 del Certificado de Conformidad (AOC) con el Informe de Conformidad AOC PCI DSS v4.0. Se agregaron los requisitos de PCI DSS v4.0. Se agregaron anexos como apoyo para nuevas respuestas a notificaciones.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Diciembre de 2022	4.0	1	Se ha eliminado "Implementado con Remediación" como opción de informe de la tabla de Respuestas a los Requisitos, de la Parte 2g del Certificado de Conformidad (AOC), de la columna de Respuestas de la Sección 2 del SAQ y de la Sección 3 del AOC. También se ha eliminado el antiguo Anexo C. Se agregó "Implementado con CCW" a la Sección 3 de AOC. Se agregó la orientación para responder a los requisitos con fecha futura. Se agregaron aclaraciones menores y se corrigieron errores tipográficos.
Enero de 2024	4.0	2	El requisito 4.2.1 se añadió a este SAQ. Este requisito, el cual ha estado presente en SAQ B-IP para las versiones anteriores de PCI DSS, se eliminó inadvertidamente cuando se actualizó este SAQ para PCI DSS v4.0.
Octubre de 2024	4.0.1		Actualizado para alinearse con PCI DSS v4.0.1. Para ver los detalles de cambios en *PCI ver PCI DSS – Resumen de Cambios de la Versión PCI DSS 4.0 a 4.0.1.* Se agregó la Guía de Recursos ASV a la sección “Recursos Adicionales PCI SSC.”

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Fecha	Versión PCI DSS	Revisión SAQ	Descripción
N/A	1.0		No utilizado.
N/A	2.0		No utilizado.
Febrero de 2014	3.0		Nuevo SAQ para abordar los requisitos aplicables a los comerciantes que procesan los datos de tarjetahabiente únicamente a través de dispositivos de punto de interacción autónomos y aprobados por la PTS con conexión IP al procesador de pagos. El contenido se alinea con los requisitos y procedimientos de prueba PCI DSS v3.0.
Abril de 2015	3.1		Actualizado para alinearse con PCI DSS v3.1. Para ver los detalles de cambios en PCI ver PCI DSS –*Resumen de Cambios de la Versión PCI DSS 3.0 a 3.1.*
Julio de 2015	3.1	1.1	Actualizado para eliminar las referencias a las "mejores prácticas" previas al 30 de junio de 2015.
Abril de 2016	3.2	1.0	Actualizado para alinearse con PCI DSS v3.2. Para ver los detalles de cambios en PCI DSS, ver PCI DSS - *Resumen de Cambios de la Versión 3.1 a 3.2.* Requisitos agregados de PCI DSS v3.2 Anexo A2.
Enero de 2017	3.2	1.1	Cambios de Documento Actualizados para aclarar los requisitos agregados en abril de 2016. Se Actualizó la Sección Antes de Empezar para aclarar el término «SCR» y la intención de los sistemas permitidos. Se añadió el Requisito 8.3.1 para alinearlo con el objetivo del Requisito 2.3. Se agregaron el Requisito 11.3.4 para verificar los controles de segmentación, si se utiliza la segmentación.
Junio de 2018	3.2.1	1.0	Actualizado para alinearse con PCI DSS v3.2.1. Para ver los detalles de cambios en PCI ver PCI DSS –*Resumen de Cambios de la Versión PCI DSS 3.2 a 3.2.1.*
Abril de 2022	4.0		Actualizado para alinearse con PCI DSS v4.0. Para ver los detalles de cambios en PCI ver PCI DSS –Resumen de Cambios de la Versión PCI DSS 3.2.1 a 4.0. Se ha reordenado, re-titulado y ampliado la información de la sección "Cómo Llenar el Cuestionario de Autoevaluación" (previamente titulada "Antes de Empezar"). Alineación del contenido de las Secciones 1 y 3 del Certificado de Conformidad (AOC) con el Informe de Conformidad AOC PCI DSS v4.0. Se agregaron los requisitos de PCI DSS v4.0. Se agregaron anexos como apoyo para nuevas respuestas a notificaciones.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Diciembre de 2022	4.0	1	Se ha eliminado "Implementado con Remediación" como opción de informe de la tabla de Respuestas a los Requisitos, de la Parte 2g del Certificado de Conformidad (AOC), de la columna de Respuestas de la Sección 2 del SAQ y de la Sección 3 del AOC. También se ha eliminado el antiguo Anexo C. Se agregó "Implementado con CCW" a la Sección 3 de AOC. Se agregó la orientación para responder a los requisitos con fecha futura. Se agregaron aclaraciones menores y se corrigieron errores tipográficos.
Enero de 2024	4.0	2	El requisito 4.2.1 se añadió a este SAQ. Este requisito, el cual ha estado presente en SAQ B-IP para las versiones anteriores de PCI DSS, se eliminó inadvertidamente cuando se actualizó este SAQ para PCI DSS v4.0.
Octubre de 2024	4.0.1		Actualizado para alinearse con PCI DSS v4.0.1. Para ver los detalles de cambios en *PCI ver PCI DSS – Resumen de Cambios de la Versión PCI DSS 4.0 a 4.0.1.* Se agregó la Guía de Recursos ASV a la sección “Recursos Adicionales PCI SSC.”

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Contenido

Cambios en el Documento i

Llenando el Cuestionario de Autoevaluación vi

Criterios de Elegibilidad del Comerciante para el Cuestionario de Autoevaluación B-IP vi

Definición de Datos del Titular de la Tarjeta, Datos de Tarjetahabiente y Datos de Autenticación Sensibles vii

Pasos para Completar la Autoevaluación PCI DSS vii

Pruebas Previstas vii

Respuestas a los Requisitos viii

Recursos Adicionales PCI SSC xi

Sección 1: Información de la Evaluación 1

Sección 2: Cuestionario de Autoevaluación B-IP 7

Construir y Mantener una Red de Sistemas Segura 7

Requisito 1: Instalar y Mantener Controles de Seguridad de la Red 7

Requisito 2: Aplicar Configuraciones Seguras a Todos los Componentes del Sistema 9

Proteger los Datos del Titular de la Tarjeta 12

Requisito 3: Proteger los Datos del Titular de la Tarjeta Almacenados 12

Requisito 4: Proteger los Datos de tarjetahabiente con Criptografía Robusta Durante la Transmisión a través de Redes Abiertas y Públicas 16

Mantener un Programa de Gestión de Vulnerabilidades 18

Requisito 6: Desarrollar y Mantener Sistemas y Softwares Seguros 18

Implementar Medidas Robustas de Control de Acceso 20

Requisito 7: Restringir el Acceso a los Componentes del Sistema y a los Datos de tarjetahabiente Según la Necesidad de Conocimiento de la Empresa 20

Requisito 8: Identificar a los Usuarios y Autenticar el Acceso a los Componentes del Sistema 21

Requisito 9: Restringir el Acceso Físico a los Datos de Tarjetahabiente 24

Monitorear y Verificar las Redes Regularmente 29

Requisito 11: Poner a Prueba Regularmente la Seguridad de los Sistemas y de las Redes 29

Mantener una Política de Seguridad de la Información 32

Requisito 12: Respaldar la Seguridad de la Información con Políticas y Programas Organizacionales 32

Anexo A: Requisitos Adicionales de PCI DSS 37

Anexo A1: Requisitos Adicionales de PCI DSS para Proveedores de Servicios Multiusuario 37

Anexo A2: Requisitos Adicionales de PCI DSS Para Entidades que Utilizan SSL / Primeras versiones de TLS para Conexiones de Terminal POS POI Presencial con Tarjetas 37

Anexo A3: Validación Complementaria de Entidades Designadas (DESV) 38

Anexo B: Ficha de Control Compensatorio 39

Anexo C: Explicación de los Requisitos Señalados como No Aplicable 40

Anexo D: Explicación de los Requisitos Señalados como No Probado 41

Sección 3: Detalles de Validación y Certificación 42

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Llenando el Cuestionario de Autoevaluación

Criterios de Elegibilidad del Comerciante para el Cuestionario de Autoevaluación B-IP

El Cuestionario de Autoevaluación (SAQ) B-IP sólo incluye aquellos Requisitos de PCI DSS aplicables a los comerciantes que procesan los datos del titular de la tarjeta únicamente a través de dispositivos de punto de interacción (POI) autónomos y aprobados por [1]PCI PIN Transaction Security (PTS) con una conexión IP al procesador de pagos.

Se aplica una excepción para los dispositivos PTS POI clasificados como Lectores de Tarjetas Seguros (SCR) y Lectores de Tarjetas Seguros para PIN (SCRP); los comerciantes que utilizan SCR o SCRP no son elegibles para este SAQ.

Los comerciantes SAQ B-IP pueden ser comerciantes de tiendas físicas (con tarjeta) o de pedidos por correo o teléfono (sin tarjeta) y no almacenan datos del titular de la tarjeta en ningún sistema informático.

Este SAQ no es aplicable a los canales de comercio electrónico.

Este SAQ no aplica para los proveedores de servicios.

Los comerciantes SAQ B-IP confirman que, para este canal de pago:

- El comerciante sólo utiliza dispositivos PTS POI autónomos y aprobados por PCI[1] Los dispositivos PTS POI (excluidos los SCR y los SCRP) conectados vía IP al procesador de pagos del comerciante para tomar la información de las tarjetas de pago de los tarjetahabientes;
- Los dispositivos POI autónomos, conectados por IP, están validados para el programa PTS POI, tal como aparece en el sitio web de PCI SSC (excluye los SCR y los SCRP);
- Los dispositivos PTS POI autónomos y conectados por IP no están conectados a ningún otro sistema dentro del entorno del comerciante (esto puede lograrse mediante la segmentación de la red para aislar los dispositivos PTS POI de otros sistemas)[2];
- La única transmisión de los datos del titular de la tarjeta se realiza desde los dispositivos PTS POI aprobados al procesador de pagos;
- El dispositivo PTS POI no depende de ningún otro dispositivo (por ejemplo, ordenador, teléfono móvil, tableta, etc.) para conectarse al procesador de pagos;
- El comerciante no almacena datos del titular de la tarjeta en formato electrónico; y
- Cualquier dato del titular de la tarjeta que el comerciante pueda conservar está impreso (por ejemplo, informes o recibos impresos), y estos documentos no se reciben electrónicamente.

---

[1] Un comerciante que utilice un dispositivo PTS POI expirado deberá comprobar con su adquirente o con las marcas de pago individuales la aceptabilidad de este SAQ. Consulte la lista PCI de Dispositivos de Seguridad para Transacciones PIN con Aprobaciones Expiradas.

[2] Este criterio no pretende prohibir que haya más de un tipo de sistema permitido (es decir, dispositivos POI conectados por IP) en la misma zona de red, siempre y cuando los sistemas permitidos estén aislados de otros tipos de sistemas (por ejemplo, implementando la segmentación de la red). Además, este criterio no pretende impedir que el tipo de sistema definido pueda transmitir la información de las transacciones a un tercero para su procesamiento, como un adquirente o un procesador de pagos, a través de una red.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Este SAQ incluye sólo los requisitos que aplican para un tipo específico de entorno comercial, tal como se define en los criterios de elegibilidad antes mencionados. Si hay Requisitos de PCI DSS aplicables al entorno de datos de tarjetahabiente que no están cubiertos en este SAQ, esto puede ser una indicación de que este SAQ no es adecuado para el entorno del comerciante.

Definición de Datos del Titular de la Tarjeta, Datos de Tarjetahabiente y Datos de Autenticación Sensibles

Los PCI DSS está destinado a todas las entidades que almacenan, procesan o transmiten datos de tarjetahabiente (CHD) y/o datos de autenticación sensibles (SAD) o que podrían afectar la seguridad de los datos del tarjetahabiente y/o sus datos de autenticación sensibles. Los datos de tarjetahabiente y los datos de autenticación sensibles se consideran datos del titular de la tarjeta y se definen de la siguiente manera:

Datos del Titular de la Tarjeta	
Los Datos de Tarjetahabiente incluyen:	**Los Datos de Autenticación Sensibles incluyen:**
• Número de Cuenta Principal (PAN) • Nombre del Tarjetahabiente • Fecha de Expiración • Código de Servicio	• Datos de pista completos (datos de banda magnética o equivalentes en un chip) • Código de Verificación de la Tarjeta • PINs / Bloques de PIN

Refiérase a la Sección 2 PCI DSS, *Información de Aplicabilidad PCI DSS*, para más detalles.

Pasos para Completar la Autoevaluación PCI DSS

1. Confirme mediante revisión de los criterios de elegibilidad en este SAQ y en el documento *Instrucciones y Lineamientos del Cuestionario de Autoevaluación* en el sitio web de PCI SSC, que se trata del SAQ correcto para el entorno del comerciante.
2. Confirme que el entorno del comerciante está correctamente enfocado.
3. Evalúe el entorno para comprobar la conformidad con los Requisitos de PCI DSS.
4. Llene todas las secciones de este documento:
   - Sección 1: Información de la Evaluación (partes 1 & 2 de la Declaración de Conformidad (AOC): Información de Contacto y Resumen Ejecutivo).
   - Sección 2: Cuestionario de Autoevaluación B-IP
   - Sección 3: Detalles de Validación y Certificación (Partes 3 & 4 de la AOC - Validación PCI DSS y Plan de Acción para Requisitos de No-Conformidad (si aplica la Parte 4)).
5. Presente el SAQ y el AOC, junto con cualquier otra documentación solicitada - tal como los informes ASV escaneados - a la organización solicitante (aquellas organizaciones que gestionan los programas de conformidad, como las marcas de pago y los adquirentes).

Pruebas Previstas

Las instrucciones que aparecen en la columna "Pruebas Previstas" se basan en los procedimientos de prueba PCI DSS y brindan una descripción de alto nivel de los tipos de actividades de prueba que se esperan que un comerciante desarrolle para verificar que se ha cumplido con un requisito.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

La intención detrás cada método de prueba se describe como sigue:

- Evalúe: El comerciante evalúa críticamente las evidencias de datos. Algunos ejemplos comunes son los documentos (electrónicos o físicos), capturas de pantalla, archivos de configuración, registros de auditoría y archivos de datos.
- Observe: El comerciante observa una acción o percibe algo en el entorno. Algunos ejemplos de sujetos de observación incluyen el desempeño del personal en una tarea o un proceso, los componentes del sistema que realizan una función o responden a una entrada, las condiciones del entorno y los controles físicos.
- Entreviste: El comerciante conversa con el personal de manera individual. Los objetivos de la entrevista pueden incluir la confirmación de si se realiza una actividad, las descripciones de cómo se realiza una actividad y si el personal tiene conocimientos o comprensión particulares.

Los métodos de prueba tienen por objeto permitir al comerciante demostrar cómo ha cumplido un requisito. Los elementos específicos que deben evaluarse u observarse y el personal que será entrevistado deben ser apropiados tanto para el requisito que se está evaluando como para la implementación particular del comerciante.

Los detalles completos de los procedimientos de prueba para cada requisito pueden encontrarse en PCI DSS.

Respuestas a los Requisitos

Para cada elemento del requisito hay una opción de respuestas para indicar la situación del comerciante con respecto a ese requisito. ***Sólo debe seleccionarse una respuesta para cada elemento del requisito.***

En la tabla siguiente se describe el significado de cada respuesta y cuándo se debe utilizar cada una de ellas:

Respuesta	Cuándo utilizar esta respuesta:
Implementado	Se han realizado las pruebas previstas y se ha cumplido con todos los elementos del requisito según lo establecido.
Implementado con CCW (Hoja de Control Compensatorio)	Se han realizado las pruebas previstas y se ha cumplido con el requisito con la ayuda de un control compensatorio. Todas las respuestas en esta columna requieren que se llene la Hoja de Control Compensatorio (CCW) que aparece en el Anexo B de este SAQ. En los Anexos B y C PCI DSS se proporciona información sobre el uso de controles compensatorios y orientación sobre cómo llenar la hoja de trabajo.
No Aplicable	Este requisito no aplica al entorno del comerciante. (Refiérase a "Orientación sobre los Requisitos No Aplicables" a continuación). Todas las respuestas en esta columna requieren una explicación de respaldo en el Anexo C de este SAQ.
No Probado	*La respuesta no es aplicable y no se incluye como opción para este SAQ.* *Este SAQ fue creado para un tipo específico de entorno basado en la forma en que el comerciante almacena, procesa y/o transmite los datos del titular de la tarjeta y define los requisitos específicos PCI DSS que aplican para este entorno. Por lo tanto, todos los requisitos de este SAQ deben ser probados.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Respuesta	Cuándo utilizar esta respuesta:
No Implementado	Algunos o todos los elementos del requisito no se han cumplido, o están en proceso de implementación, o requieren más pruebas antes de que el comerciante pueda confirmar que han sido implementados. Las respuestas de esta columna pueden requerir la ejecución de la Parte 4 si así lo solicita la entidad a la que se presentará este SAQ. Esta respuesta también se utiliza si un requisito no puede cumplirse debido a una restricción legal. (Para más orientación refiérase a "Excepción legal" más adelante).

Orientación sobre los Requisitos No Aplicables

Si algún requisito no aplica para el entorno del comerciante, seleccione la opción No Aplicable para ese requisito específico. Por ejemplo, en este SAQ, los requisitos para asegurar todos los medios con los datos de tarjetahabiente (Requisitos 9.4.1 - 9.4.6) sólo se aplican si el comerciante almacena medios en papel con datos de tarjetahabiente; si no se almacenan medios en papel, el comerciante puede seleccionar No Aplicable para esos requisitos.

Para cada respuesta en la que se seleccione No Aplicable en este SAQ, llene el *Anexo C*: *Explicación de los Requisitos Señalados como No Aplicable.*

Orientación para Responder a Requisitos con Fecha Futura

En la Sección 2 a continuación, cada requisito o punto PCI DSS con un período de implementación extendido incluye la siguiente nota: *"Este requisito [o punto] es una práctica recomendada hasta el 31 de marzo de 2025, fecha a partir de la cual será obligatorio y deberá tenerse en cuenta en su totalidad durante una evaluación PCI DSS.*

No se requiere que estos nuevos requisitos se incluyan en una evaluación PCI DSS hasta que haya pasado la fecha futura. Antes de esa fecha futura, cualquier requisito con una fecha de implementación extendida que no haya sido implementado por el comerciante puede marcarse como No aplicable y documentarse en el *Anexo C: Explicación de los Requisitos Señalados como No Aplicable***.**

Excepción Legal

Si su organización está sujeta a una restricción legal que le impide cumplir con un requisito de PCI DSS, seleccione No Implementado para ese requisito y llene la declaración correspondiente en la Sección 3, Parte 3 de este SAQ.

Nota: *Una excepción legal es una restricción legal debido a una ley, regulación o requisito regulatorio local o regional, donde cumplir con un requisito del PCI DSS violaría esa ley, regulación o requisito regulatorio. Las obligaciones contractuales o el asesoramiento legal no son restricciones legales.*

Las obligaciones contractuales o el asesoramiento legal no son restricciones legales.

Uso del Enfoque Personalizado

Los SAQ no pueden utilizarse para documentar el uso del Enfoque Personalizado para cumplir los requisitos de PCI DSS. Por tal razón, los Objetivos del Enfoque Personalizado no se incluyen en los SAQ. Las entidades que deseen validar el uso del Enfoque Personalizado pueden utilizar la Plantilla de Informe de Conformidad (ROC) PCI DSS para documentar los resultados de su evaluación.

El Uso del Enfoque Personalizado no está contemplado en los SAQ.

El uso del enfoque personalizado puede ser regulado por las organizaciones que administran los programas de conformidad, como las marcas de pago y los adquirentes. Las preguntas sobre el uso de

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

un enfoque personalizado deben remitirse siempre a esas organizaciones. Esto incluye si una entidad que es elegible para un SAQ puede, en cambio, completar un ROC para usar un enfoque personalizado, y si se requiere que una entidad utilice QSA, o puede usar un ISA, para completar una evaluación utilizando el enfoque personalizado. La información acerca del uso del Enfoque Personalizado puede encontrarse en los Anexos D y E de PCI DSS.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Recursos Adicionales PCI SSC

A continuación, se ofrecen recursos adicionales que proporcionan orientación sobre los Requisitos de PCI DSS y sobre cómo llenar el cuestionario de autoevaluación para ayudarle en el proceso de evaluación.

Recurso	Incluye:
Requisitos y Procedimientos de Prueba del Estándar de Seguridad de Datos PCI (PCI DSS)	▪ Orientación sobre el Alcance ▪ Orientación sobre el objetivo de todos los Requisitos de PCI DSS ▪ Detalles de los Procedimientos de Prueba ▪ Guía de los Controles Compensatorios ▪ Anexo G: Glosario de Términos, Abreviaturas y Acrónimos
Instrucciones y Directrices SAQ	▪ Información sobre todos los SAQ y sus Criterios de Elegibilidad ▪ Cómo determinar qué SAQ es el adecuado para su organización
Preguntas Frecuentes (FAQ)	▪ Orientación e Información acerca de los SAQ.
Glosario PCI DSS en línea	▪ Términos, Abreviaturas y Acrónimos PCI DSS
Información Complementaria y Directrices	▪ Directrices en varios temas PCI DSS incluyendo: – *Comprendiendo el Alcance PCI DSS y la Segmentación de la Red.* – *Garantía de Seguridad de Terceros* – *Orientación sobre la Autenticación Multifactorial* – *Mejores Prácticas para Mantener la Conformidad con PCI DSS*
Introducción a PCI	▪ Recursos para pequeños comerciantes, incluyendo: – *Guía de Pagos Seguros* – *Sistemas de Pago Comunes* – *Preguntas que hacer a sus Proveedores* – *Glosario de Términos de Seguridad de Pagos e Información* – *Conceptos Básicos PCI Firewall* – *Guía de Recursos ASV*

Estos y otros recursos pueden encontrarse en el sitio web del PCI SSC *(www.pcisecuritystandards.org)*.

Se aconseja a las organizaciones que revisen los documentos PCI DSS y otros documentos de respaldo antes de comenzar una evaluación.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Sección 1: Información de la Evaluación

Instrucciones para la Presentación

Este documento debe ser completado como una declaración de los resultados de la autoevaluación del comerciante en lo relativo con respecto a los Requisitos y *Procedimientos de Prueba del Estándar de Seguridad de Datos de Payment Card Industry (PCI DSS)* Complete todas las secciones. El comerciante es responsable de garantizar que cada sección sea completada por las partes pertinentes, según corresponda. Póngase en contacto con la(s) entidad(es) que recibirán el AOC para los procedimientos de elaboración de informe y presentación.

Parte 1. Información de Contacto

Parte 1a. Comerciante Evaluado	
Nombre de la compañía:	
DBA (actuando comercialmente como):	
Dirección postal de la compañía:	
Sitio web principal de la compañía:	
Nombre del contacto de la compañía:	
Título del contacto de la compañía:	
Número de teléfono de contacto:	
Dirección de correo electrónico de contacto:	

Parte 1b. Asesor	
Provea la siguiente información sobre todos los asesores que participaron en la evaluación. Si no hubo ningún asesor para un tipo de asesor determinado, introduzca No aplicable.	
Asesor(es) de Seguridad Interna del PCI SSC	
Nombre del ISA:	
Asesor de Seguridad Calificado	
Nombre de la compañía:	
Dirección postal de la compañía:	
Página web de la compañía:	
Nombre del Asesor principal:	
Número de teléfono del asesor:	
Dirección de correo electrónico del asesor:	
Número de Certificado del asesor:	

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo

Parte 2a. Canales de Pago del Comerciante (seleccione todos los que apliquen):

Indique todos los canales de pago utilizados por la empresa que se incluyen en esta Evaluación.

☐ Pedido por correo/por teléfono (MOTO)

☐ Comercio Electrónico

☐ Presencial

¿Hay algún canal de pago que no esté incluido en esta evaluación? En caso afirmativo, indique qué canal(les) no están incluidos en la evaluación y explique brevemente por qué se han excluido.	☐ Sí ☐ No

Nota: Si el comerciante tiene un canal de pago no cubierto por esta SAQ, consulte con la(s) entidad(es) a la(s) que se presentará esta *AOC* acerca de la validación para los otros canales.

Parte 2b. Descripción de la Función con Tarjetas de Pago

Para cada canal de pago incluido en esta Evaluación seleccionado en la Parte 2a previa, describa cómo la empresa almacena, procesa y/o transmite los datos del titular de la tarjeta.

Canal	**Cómo la Empresa Almacena, Procesa y/o Transmite los Datos del Titular de la Tarjeta**

Parte 2c. Descripción del Entorno de las Tarjetas de Pago

Proporcione una descripción de ***alto- nivel*** del entorno cubierto por esta evaluación. *Por ejemplo:* • *Conexiones desde y hacia el entorno de datos de tarjetahabiente (CDE).* • *Componentes críticos del sistema dentro del CDE, tales como los dispositivos POI, las bases de datos, los servidores web, etc., y cualquier otro componente de pago necesario, según corresponda.* • *Componentes del sistema que podrían afectar la seguridad de los datos del titular de la tarjeta.*	
Indique si el entorno incluye la segmentación para reducir el alcance de la evaluación. *(Consulte la sección "Segmentación" de PCI DSS para obtener orientación sobre la segmentación).*	☐ Sí ☐ No

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo *(continuación)*

Parte 2d. Localidades e Instalaciones en el Ámbito de Aplicación

Enumere todos los tipos de ubicaciones físicas/instalaciones (por ejemplo, establecimientos minoristas, oficinas corporativas, centros de datos, centros de llamadas y salas de correo) dentro el ámbito de la evaluación PCI DSS.

Tipo de Instalación	**Número total de Instalaciones** (Cuántas instalaciones de este tipo se encuentran dentro del ámbito)	**Ubicación(ones) de las Instalaciones (ciudad, país)**
Ejemplo: Centros de Datos	*3*	*Boston, MA, USA*

Parte 2e. Productos y Soluciones Validados por PCI SSC

¿Utiliza el comerciante algún elemento identificado en alguna de las Listas de Productos y Soluciones Validados por PCI SSC♦?

☐ Sí ☐ No

Provea la siguiente información sobre cada elemento que el comerciante utilice de las Listas de Productos y Soluciones Validados por PCI SSC:

Nombre del Producto o Solución Validado por PCI SSC	**Versión del Producto o Solución**	**Estándar PCI SSC según el cual se validó el producto o la solución**	**Número de Referencia de la Lista PCI SSC**	**Fecha de Expiración de la Lista** (DD-MM-AAAA)

♦ Para los fines de este documento, se entenderá por "Listas de Productos y Soluciones Validados" las listas de productos, soluciones y/o componentes validados que aparecen en el sitio web de PCI SSC (www.pcisecuritystandards.org) por ejemplo, los Kits de Desarrollo de Software 3DS, los Dispositivos PTS Aprobados, el Software de Pago Validado, las Soluciones Cifradas de Punto a Punto (P2PE), las Soluciones de Introducción de PIN basadas en software en COTS (SPoC), las Soluciones de Pago sin contacto en COTS (CPoC) y los Productos de Métodos de Pagos Móviles en COTS (MPoC).

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo *(continuación)*

Parte 2f. Proveedores de Servicios Externos

Tiene el comerciante relaciones con uno o más proveedores de servicios externos que:

• Almacenan, procesan o transmiten datos del titular de la tarjeta en nombre del comerciante (por ejemplo, pasarelas de pago, procesadores de pago, proveedores de servicios de pago (PSP) y almacenamiento externo).	☐ Sí ☐ No
• Gestionar los componentes del sistema incluidos en el ámbito de la evaluación PCI DSS del comerciante, por ejemplo, a través de servicios de control de seguridad de la red, servicios antimalware, gestión de eventos e incidentes de seguridad (SIEM), centros de contacto y de llamadas, servicios de alojamiento web y proveedores de IaaS, PaaS, SaaS y FaaS en la nube.	☐ Sí ☐ No
• Podría afectar la seguridad del CDE del comerciante (por ejemplo, proveedores que prestan asistencia a través de acceso remoto, y/o desarrolladores de software a la medida).	☐ Sí ☐ No

En Caso Afirmativo:

Nombre del Proveedor de Servicio:	**Descripción del servicio(s) prestado(s):**

Nota: *El requisito 12.8 aplica a todas las entidades de esta lista.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo *(continuación)*

Parte 2g. Resumen de la Evaluación
(Sección 2 del SAQ y anexos relacionados)

Indique a continuación todas las respuestas seleccionadas para cada requisito de PCI DSS.

Requisito de PCI DSS*	Respuestas a los Requisitos *Se puede seleccionar más de una respuesta para un requisito determinado. Indique todas las respuestas que correspondan.*			
	Implementado	Implementado con CCW	No Aplicable	No Implementado
Requisito 1:	☐	☐	☐	☐
Requisito 2:	☐	☐	☐	☐
Requisito 3:	☐	☐	☐	☐
Requisito 4:	☐	☐	☐	☐
Requisito 6:	☐	☐	☐	☐
Requisito 7:	☐	☐	☐	☐
Requisito 8:	☐	☐	☐	☐
Requisito 9:	☐	☐	☐	☐
Requisito 11:	☐	☐	☐	☐
Requisito 12:	☐	☐	☐	☐
Anexo A2:	☐	☐	☐	☐

** Los Requisitos de PCI DSS indicados anteriormente se refieren a los requisitos de la Sección 2 de este SAQ.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 2. Resumen Ejecutivo *(continuación)*

Parte 2h. Elegibilidad para Llenar el SAQ B-IP

El comerciante certifica la elegibilidad para llenar este Cuestionario de Autoevaluación para este canal de pago porque:

☐	El comerciante sólo utiliza dispositivos PTS POI autónomos y aprobados por PCI Los dispositivos PTS POI (excluidos los SCR y los SCRP) conectados vía IP al procesador de pagos del comerciante para tomar la información de las tarjetas de pago de los tarjetahabientes;
☐	Los dispositivos POI autónomos, conectados por IP, están validados para el programa PTS POI, tal como aparece en el sitio web PCI SSC (excluye los SCR y los SCRP);
☐	Los dispositivos PTS POI autónomos y conectados por IP no están conectados a ningún otro sistema dentro del entorno del comerciante (esto puede lograrse mediante la segmentación de la red para aislar los dispositivos PTS POI de otros sistemas);
☐	La única transmisión de los datos del titular de la tarjeta se realiza desde los dispositivos PTS POI aprobados al procesador de pagos;
☐	El dispositivo PTS POI no depende de ningún otro dispositivo (por ejemplo, ordenador, teléfono móvil, tableta, etc.) para conectarse al procesador de pagos;
☐	El comerciante no almacena datos del titular de la tarjeta en formato electrónico.
☐	Cualquier dato del titular de la tarjeta que el comerciante pueda conservar está impreso (por ejemplo, informes o recibos impresos), y estos documentos no se reciben electrónicamente.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Sección 2: Cuestionario de Autoevaluación B-IP

Nota: *Los siguientes requisitos son un reflejo de los requisitos del documento* Requisitos y Procedimientos de Prueba PCI DSS.

Fecha de finalización de la autoevaluación: DD-MM-AAAA

Construir y Mantener una Red de Sistemas Segura

Requisito 1: Instalar y Mantener Controles *de Seguridad de la Red*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
1.2 Se configuran y mantienen los controles de seguridad de la red (NSC).						
1.2.3	Se mantienen diagramas de red precisos que muestran todas las conexiones entre el CDE y otras redes, incluyendo las redes inalámbricas.	• Evalúe los diagramas de red. • Evalúe las configuraciones de redes. • Entreviste al personal responsable.	☐	☐	☐	☐
	Notas de Aplicabilidad Se puede utilizar un(os) diagrama(s) de red vigente(s) u otra solución técnica o topológica que identifique las conexiones y dispositivos en la red para cumplir con este requisito.					
1.2.5	Todos los servicios, protocolos y puertos permitidos están identificados, aprobados y tienen una necesidad de negocio definida.	• Evalúe la documentación. • Evalúe los ajustes de configuración.	☐	☐	☐	☐
1.2.6	Las configuraciones de seguridad son definidas e implementadas para todos los servicios, protocolos y puertos que están en uso y que son considerados inseguros, de tal manera que el riesgo es mitigado.	• Evalúe la documentación. • Evalúe los ajustes de configuración.	☐	☐	☐	☐

Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información acerca del significado de estas opciones de respuesta.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
1.3 El acceso a la red hacia y desde el entorno de datos de tarjetahabiente está restringido.						
1.3.1	El tráfico de entrada al CDE está restringido de la siguiente manera: • Sólo al tráfico necesario. • Todo el resto del tráfico está específicamente denegado.	• Evalúe los estándares de configuración del NSC. • Evalúe las configuraciones del NSC.	☐	☐	☐	☐
1.3.2	El tráfico saliente del CDE se restringe de la siguiente manera: • Sólo al tráfico necesario. • Todo el resto del tráfico está específicamente denegado.	• Evalúe los estándares de configuración del NSC. • Evalúe las configuraciones del NSC.	☐	☐	☐	☐
1.3.3	Los NSC se implementan entre todas las redes inalámbricas y el CDE; esto es independientemente de que la red inalámbrica sea parte CDE o no, de manera que: • Todo el tráfico inalámbrico de las redes inalámbricas hacia el CDE es denegado de forma explícita. • Sólo se permite el tráfico inalámbrico al CDE que tenga un propósito comercial autorizado.	• Evalúe los ajustes de configuración. • Evalúe los diagramas de red.	☐	☐	☐	☐
1.4 Se controlan las conexiones de red entre las redes fiables y las que no lo son.						
1.4.3	Se implementan medidas *Antispoofing* para detectar y bloquear la entrada a la red confiable de direcciones IP origen falsas o suplantadas.	• Evalúe la documentación NSC. • Evalúe las configuraciones del NSC.	☐	☐	☐	☐

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito 2: Aplicar Configuraciones Seguras a Todos los Componentes del Sistema

Nota: *Para SAQ B-IP, el Requisito 2 se aplica a los dispositivos de firewall/enrutador en la red del comerciante que conectan sus dispositivos PTS POI al procesador de pagos.*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
2.2 Los componentes del sistema se configuran y administran de forma segura.						
2.2.2	Las cuentas predeterminadas del proveedor se gestionan de la siguiente manera: • Si se utilizan las cuentas predeterminadas del proveedor, la contraseña predeterminada se cambia según el requisito 8.3.6. • Si no se van a utilizar las cuentas predeterminadas del proveedor, la cuenta se elimina o se desactiva.	• Evalúe los estándares de configuración del sistema. • Evalúe la documentación del proveedor. • Observe a un administrador del sistema iniciando sesión con las cuentas predeterminadas del proveedor. • Evalúe los archivos de configuración. • Entreviste al personal.	☐	☐	☐	☐
	Notas de Aplicabilidad Esto se aplica a TODAS las cuentas y contraseñas predeterminadas del proveedor, incluidas, entre otras, las utilizadas por los sistemas operativos, el software que proporciona servicios de seguridad, las cuentas de aplicaciones y sistemas, los terminales de punto de venta (POS), las aplicaciones de pago y los valores predeterminadas del Protocolo Simple de Administración de Red (SNMP). Este requisito también se aplica cuando un componente del sistema no está instalado en el entorno de una entidad, por ejemplo, el software y las aplicaciones que forman parte del CDE y a las que se ingresa a través de un servicio de suscripción en la nube.					

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
2.2.7	Todo el acceso administrativo sin consola está cifrado utilizando criptografía robusta.	• Evalúe los estándares de configuración del sistema. • Observe el inicio de sesión de un administrador. • Evalúe las configuraciones del sistema. • Evalúe la documentación del proveedor. • Entreviste al personal.	☐	☐	☐	☐
	Notas de Aplicabilidad Esto incluye el acceso administrativo a través de interfaces basadas en navegador e interfaces de programación de aplicaciones (API).					
2.3 Los entornos inalámbricos se configuran y administran de forma segura.						
2.3.1	Para entornos inalámbricos conectados al CDE o que transmiten datos del titular de la tarjeta, todos los valores predeterminados de los proveedores inalámbricos se cambian en la instalación o se confirma que son seguros, incluidos, entre otros: • Claves de cifrado inalámbricas predeterminadas. • Contraseñas o puntos de acceso inalámbricos. • Valores predeterminados de SNMP. • Cualquier otro proveedor inalámbrico predeterminado relacionado con la seguridad.	• Evalúe las políticas y procedimientos. • Revise la documentación del proveedor. • Evalúe los ajustes de configuración inalámbrica. • Entreviste al personal.	☐	☐	☐	☐
	Notas de Aplicabilidad Esto incluye, pero no se limita a, las claves de encriptación inalámbrica predeterminadas, las contraseñas de los puntos de acceso inalámbricos, los valores predeterminados de SNMP y cualquier otro valor predeterminado del proveedor inalámbrico relacionado con la seguridad.					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
2.3.2	Para los entornos inalámbricos conectados al CDE o que transmitan datos del titular de la tarjeta, las claves cifradas inalámbricas se cambian como sigue: • Siempre que el personal con conocimiento de la clave deje la empresa o la función para la que era necesario el conocimiento. • Siempre que se sospeche o se sepa que una clave está comprometida.	• Evalúe la documentación clave de administración. • Entreviste al personal.	☐	☐	☐	☐

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Proteger los Datos del Titular de la Tarjeta

Requisito 3: Proteger los Datos del Titular de la Tarjeta Almacenados

Nota: *En el caso de SAQ B-IP, el Requisito 3 sólo se aplica a los comerciantes con registros en papel que incluyan datos del titular de la tarjeta (por ejemplo, recibos o informes impresos).*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
3.1 Se definen y comprenden los procesos y mecanismos para proteger los datos del titular de la tarjeta almacenados.						
3.1.1	Todas las políticas de seguridad y procedimientos operativos que se identifican en el Requisito 3 son: • Documentados. • Actualizados. • En uso. • Conocidos por todas las partes involucradas.	• Evalúe la documentación. • Entreviste al personal.	☐	☐	☐	☐

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para el Requisito 3.1.1 significa que, si el comerciante almacena los datos del titular de la tarjeta en papel, el comerciante dispone de políticas y procedimientos que rigen sus las actividades con respecto al Requisito 3. Esto ayuda a garantizar que el personal conoce y sigue las políticas de seguridad y los procedimientos operativos documentados para gestionar el almacenamiento seguro de cualquier registro en papel con datos del titular de la tarjeta.

Si el comerciante no almacena registros en papel con datos del titular de la tarjeta, marque este requisito como No aplicable y llene el Anexo C: Explicación de los Requisitos Señalados como No Aplicable.

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
3.3 Los datos de autenticación sensibles (SAD) no se almacenan después de la autorización.						
3.3.1	Los SAD no se almacenan después de la autorización, incluso si están cifrados. Todos los datos de autenticación sensibles recibidos se vuelven irrecuperables una vez finalizado el proceso de autorización.	• Evalúe las políticas y procedimientos documentados. • Evalúe las configuraciones del sistema. • Observe los procesos de eliminación de datos seguros.	☐	☐	☐	☐
	Notas de Aplicabilidad *Parte de esta Nota de Aplicabilidad se eliminó intencionadamente para este SAQ, ya que no se aplica a las evaluaciones de los comerciantes.* Los datos de autenticación sensibles incluyen los datos citados en los Requisitos 3.3.1.1 hasta el 3.3.1.2.					
3.3.1.1	El contenido completo de cualquier pista no se almacena una vez finalizado el proceso de autorización.	• Evalúe las fuentes de datos.	☐	☐	☐	☐
	Notas de Aplicabilidad En el curso normal de los negocios, es posible que sea necesario conservar los siguientes elementos de datos de la pista: • Nombre del tarjetahabiente. • Número de cuenta principal (PAN). • Fecha de expiración. • Código de servicio. Para minimizar el riesgo, almacene de forma segura sólo estos elementos de datos según sea necesario para la empresa.					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
3.3.1.2	El código de verificación de la tarjeta no se almacena una vez finalizado el proceso de autorización.	• Evalúe las fuentes de datos.	☐	☐	☐	☐
	Notas de Aplicabilidad El código de verificación de la tarjeta es el número de tres o cuatro dígitos impresos en el anverso o el reverso de una tarjeta de pago y que se utiliza para verificar las transacciones sin tarjeta presente.					
Guía para llenar el SAQ: *La selección de cualquiera de las respuestas Implementado para el requisito 3.3.1.2 significa que si el comerciante anota el código de verificación de la tarjeta mientras se realiza una transacción, el comerciante destruye el papel de forma segura (por ejemplo, con una trituradora) inmediatamente después de finalizar la transacción, u oculta el código (por ejemplo, "tachándolo" con un rotulador) antes de guardar el papel.* *Si el comerciante nunca solicita el número de tres o cuatro dígitos impresos en el anverso o el reverso de una tarjeta de pago ("código de verificación de la tarjeta"), marque este requisito como No Aplicable y llene el Anexo C: Explicación de los Requisitos Señalados como No Aplicable.*						
3.3.1.3	El número de identificación personal (PIN) y el bloque del PIN no se almacenan una vez finalizado el proceso de autorización.	• Evalúe las fuentes de datos.	☐	☐	☐	☐
	Notas de Aplicabilidad Los bloques de PIN se cifran durante el curso natural de los procesos de transacción, pero incluso si una entidad cifra el bloque de PIN nuevamente, todavía no se permite que se almacene después de la finalización del proceso de autorización.					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
3.4 El acceso a las pantallas de datos PAN completas y la capacidad de copiar los datos PAN están restringidos.						
3.4.1	Los datos PAN están enmascarados cuando se muestran (el BIN y los últimos cuatro dígitos constituyen el número máximo de dígitos que se muestran), de manera que sólo el personal con una necesidad legítima de negocios pueda ver más que el BIN y los últimos cuatro dígitos de los datos PAN.	• Evalúe las políticas y procedimientos documentados. • Evalúe las configuraciones del sistema. • Evalúe la lista documentada de los roles que necesitan tener acceso a algo más que el BIN y a los últimos cuatro dígitos del PAN (incluye el PAN completo). • Evalúe la presentación del PAN (por ejemplo, en la pantalla, en los recibos de papel).	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no sustituye a otros más estrictos para la visualización de los datos de tarjetahabiente, por ejemplo, los requisitos legales o de las marcas de pago para los recibos de los puntos de venta (POS). Este requisito se refiere a la protección de los datos PAN cuando se muestran en pantallas, recibos de papel, impresiones, etc., y no debe confundirse con el requisito 3.5.1 para la protección de los datos PAN cuando se almacenan, se procesan o se transmiten.					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito 4: Proteger los Datos de Tarjetahabiente con Criptografía Robusta Durante la Transmisión a través de Redes Abiertas y Públicas

Requisito PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
4.2 Los PAN están protegidos con criptografía sólida durante la transmisión.						
4.2.1	Se implementan fuertes protocolos de seguridad y criptografía de la siguiente manera para proteger los datos PAN durante la transmisión a través de redes públicas abiertas:					
	• Solo se aceptan claves y certificados confiables.	• Evalúe las políticas y procedimientos documentados. • Entreviste al personal • Evalúe las configuraciones del sistema. • Evalúe las transmisiones de datos de tarjetahabiente. • Evalúe las claves y los certificados.	☐	☐	☐	☐
	• Los certificados utilizados para proteger los datos PAN durante la transmisión a través de redes públicas abiertas se confirman como válidos y no están vencidos ni revocados. *Este punto es una de las mejores prácticas hasta su fecha de vigencia; consulte las notas de aplicabilidad a continuación para obtener más detalles.*		☐	☐	☐	☐
	• El protocolo en uso sólo admite versiones o configuraciones seguras y no admite el apoyo ni el uso de versiones, algoritmos, tamaños de clave o implementaciones inseguras.		☐	☐	☐	☐
	• La fuerza del cifrado es apropiada para la metodología de cifrado en uso. *(continuación)*		☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito PCI DSS		Pruebas Previstas	Respuesta* (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
	Notas de Aplicabilidad *Parte de esta nota de aplicabilidad se eliminó intencionalmente, ya que no aplica a este SAQ.* *El punto anterior (para confirmar que los certificados utilizados para proteger los datos PAN durante la transmisión a través de redes públicas abiertas son válidos y no están vencidos ni revocados) es una mejor práctica hasta el 31 de marzo de 2025, después de lo cual se requerirá como parte del Requisito 4.2.1 y debe tenerse en cuenta en su totalidad durante una evaluación PCI DSS.*					

Guía para llenar el SAQ:

*La selección de cualquiera de las respuestas existentes para el requisito 4.2.1 significa que el comerciante confirmó que se implementaron controles de criptografía y seguridad sólidos para salvaguardar a PAN durante la transmisión a través de redes públicas abiertas, **ya sea** porque 1) los controles están habilitados y activos en el dispositivo PTS POI o porque 2) el comerciante implementó controles que proporcionan esta funcionalidad.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Mantener un Programa de Gestión de Vulnerabilidades

Requisito 6: Desarrollar y Mantener Sistemas y Softwares Seguros

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
6.3 Las vulnerabilidades de seguridad se identifican y son abordadas.						
Nota: *Para el SAQ B-IP, este requisito se aplica a los dispositivos firewall/router del comerciante que conectan sus dispositivos PTS POI con el procesador de pagos. La identificación y la gestión de las vulnerabilidades de seguridad de los dispositivos PTS POI suelen ser gestionadas por el proveedor o el procesador de terminales del comerciante. El comerciante debería contactar a la entidad que gestiona sus terminales para entender cómo está en conformidad con este requisito y las responsabilidades del comerciante y de la entidad que gestiona los terminales.*						
6.3.1	Las vulnerabilidades de seguridad se identifican y gestionan de la siguiente manera: • Las nuevas vulnerabilidades de seguridad se identifican utilizando fuentes reconocidas por la industria de información de vulnerabilidad de la seguridad, incluyendo alertas de equipos internacionales y nacionales de respuesta a emergencias informáticas (CERTs). • A las vulnerabilidades se les asigna una clasificación de riesgo basada en las mejores prácticas de la industria y considerando su impacto potencial. • Las clasificaciones de riesgo identifican, como mínimo, todas las vulnerabilidades consideradas de alto riesgo o críticas para el entorno. • *Punto dejado en blanco intencionadamente para este SAQ.* *(continuación)*	• Evalúe las políticas y procedimientos. • Entreviste al personal responsable. • Evalúe la documentación • Observe los procesos.	☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

	Requisito de PCI DSS	Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
	Notas de Aplicabilidad Este requisito no se consigue con los escaneos, y es adicional a la realización de los escaneos de vulnerabilidades realizados para los Requisitos 11.3.1 y 11.3.2. Este requisito se refiere a un proceso para monitorizar activamente las fuentes de la industria en materia de información de vulnerabilidades y para que la entidad determine la clasificación de riesgo que se asociará con cada vulnerabilidad.					
6.3.3	Todos los componentes del sistema están protegidos contra vulnerabilidades conocidas mediante la instalación de parches/actualizaciones de seguridad aplicables de la siguiente manera: • Los parches/ actualizaciones para vulnerabilidades críticas (identificados de acuerdo con el proceso de clasificación de riesgos del Requisito 6.3.1) se instalan dentro del período de un mes de su emisión. • *Punto dejado en blanco intencionadamente para este SAQ.*	• Evalúe las políticas y procedimientos. • Evalúe los componentes del sistema y software relacionado. • Compare la lista de parches de seguridad instalados con las listas de parches del proveedor recientes.	☐	☐	☐	☐

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Implementar Medidas Robustas de Control de Acceso

Requisito 7: Restringir el Acceso a los Componentes del Sistema y a los Datos de Tarjetahabiente Según la Necesidad de Conocimiento de la Empresa

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
7.2 El acceso a los componentes y datos del sistema se define y asigna adecuadamente.						
7.2.2	El acceso se asigna a los usuarios, incluidos los privilegiados, en función de: • La clasificación y función del trabajo. • Los privilegios mínimos necesarios para realizar las responsabilidades del trabajo.	• Evalúe las políticas y procedimientos. • Evalúe la configuración de acceso de los usuarios, incluso de los privilegiados. • Entreviste al personal administrativo responsable. • Entreviste al personal responsable de asignar el acceso.	☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito 8: Identificar a los Usuarios y Autenticar el Acceso a los Componentes del Sistema

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.1 Los procesos y mecanismos para identificar a los usuarios y autenticar el acceso a los componentes del sistema están definidos y comprendidos.						
8.1.1	Todas las políticas de seguridad y procedimientos operativos que se identifican en el Requisito 8 están: • Documentados. • Actualizados. • En uso. • Conocidos por todas las partes involucradas.	• Evalúe la documentación. • Entreviste al personal.	☐	☐	☐	☐
Guía para llenar el SAQ: *La selección de cualquiera de las respuestas Implementado para el Requisito 8.1.1 significa que el comerciante cuenta con políticas y procedimientos Implementados que rigen las actividades el comerciante para el Requisito 8.*						

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.2 La identificación de usuarios y las cuentas relacionadas para usuarios y administradores se gestionan estrictamente durante el ciclo de vida de una cuenta.						
8.2.2	Las identificaciones IDs de grupos, compartidas o genéricas, u otras credenciales de autenticación compartidas sólo se usan cuando es necesario, de manera excepcional, y se administran de la siguiente manera: • Se impide el uso de la ID a menos que se requiera por una circunstancia excepcional. • Su uso está limitado al tiempo necesario para la circunstancia excepcional. • La justificación de negocio para su uso está documentada. • Su uso está explícitamente aprobado por la dirección. • La identidad del usuario individual se confirma antes de que se conceda el acceso a una cuenta. • Cada acción realizada es atribuible a un usuario individual.	• Evalúe las listas de cuentas de usuario en los componentes del sistema y la documentación aplicable. • Evalúe las políticas y procedimientos de autenticación. • Entreviste a los administradores del sistema.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito no está destinado a aplicarse a las cuentas de usuario de los terminales de punto de venta que sólo tienen acceso a un número de tarjeta simultáneamente para procesar una única transacción.					
8.2.7	Las cuentas utilizadas por terceros para acceder, respaldar o mantener componentes del sistema a través del acceso remoto se administran de la siguiente manera: • Son habilitadas solamente durante el período de tiempo necesario y son deshabilitadas cuando no están en uso. • Su uso es monitorizado para detectar cualquier actividad inesperada.	• Entreviste al personal responsable. • Evalúe la documentación para la gestión de las cuentas. • Evalúe la evidencia.	☐	☐	☐	☐

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
8.4 Se implementa la autenticación Múltiples Factores (MFA) para proteger el acceso al CDE.						
8.4.3	Los MFA se implementan para todos los accesos a redes remotas que se originan fuera de la red de la entidad y que podrían ingresar o impactar el CDE.	• Evalúe las configuraciones de la red y/o del sistema para los servidores y sistemas de acceso remoto. • Observe al personal (por ejemplo, usuarios y administradores) y terceros que se conecta de forma remota a la red.	☐	☐	☐	☐
	Notas de Aplicabilidad El requisito de los MFA para el acceso remoto que se origina desde fuera de la red de la entidad se aplica a todas las cuentas de usuario que pueden ingresar a la red de forma remota, donde ese acceso remoto conduce o podría conducir a un acceso al CDE. Esto incluye todos los accesos remotos del personal (usuarios y administradores) y los terceros (incluidos, entre otros, los vendedores, proveedores de servicios y clientes). Si el acceso remoto se realiza a una parte de la red de la entidad que está correctamente segmentada del CDE, de manera que los usuarios remotos no puedan ingresar al CDE o afectarlo, no se requiere MFA para el acceso remoto a esa parte de la red. Sin embargo, se requieren los MFA para cualquier acceso remoto a redes con acceso al CDE y se recomienda para todos los accesos remotos a las redes de la entidad. Los requisitos de los MFA se aplican a todos los tipos de componentes del sistema, incluyendo la nube, los sistemas alojados y las aplicaciones locales, los dispositivos de seguridad de red, las estaciones de trabajo, los servidores y los puntos finales, e incluye el acceso directo a las redes o sistemas de una entidad, así como el acceso basado en web a una aplicación o función.					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito 9: Restringir el Acceso Físico a los Datos de Tarjetahabiente

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
9.1 Se definen y comprenden los procesos y mecanismos para restringir el ingreso físico a los datos de tarjetahabiente.						
9.1.1	Todas las políticas de seguridad y procedimientos operativos que se identifican en el Requisito 9 están: • Documentados. • Actualizados. • En uso. • Conocidos por todas las partes involucradas.	• Evalúe la documentación. • Entreviste al personal.	☐	☐	☐	☐
Guía para llenar el SAQ: *La selección de cualquiera de las respuestas Implementado para el Requisito 9.1.1 significa que el comerciante cuenta con políticas y procedimientos implementados que rigen las actividades del comerciante para el Requisito 9, incluyendo cómo cualquier medio impreso con información de datos de tarjetahabiente es protegido, y cómo los dispositivos POI son protegidos.*						
9.2 Los controles de acceso físico gestionan la entrada a las instalaciones y sistemas que contengan datos de tarjetahabiente.						
9.2.2	Se implementan controles físicos y/o lógicos para restringir el uso de tomas (o puertos) de red de acceso público dentro de la instalación.	• Entreviste al personal responsable. • Observe la ubicación de los conectores de red de acceso público.	☐	☐	☐	☐
9.4 Los medios con datos de tarjetahabiente se almacenan, acceden, distribuyen y destruyen de forma segura.						
Nota: *Para el SAQ B-IP, los Requisitos del punto 9.4 sólo se aplican a los comerciantes con registros en papel (por ejemplo, recibos o informes impresos) con datos del titular de la tarjeta, incluidos los números de cuenta principales (PAN).*						
9.4.1	Todos los medios con datos de tarjetahabiente están protegidos físicamente.	• Evalúe la documentación.	☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
9.4.1.1	Las copias de seguridad sin conexión con los datos de tarjetahabiente se almacenan en una ubicación segura.	• Evalúe los procedimientos documentados. • Evalúe los registros u otra documentación. • Entreviste al personal responsable de en el sitio de almacenamiento.	☐	☐	☐	☐
9.4.2	Todos los datos de tarjetahabiente se clasifican de acuerdo con la confidencialidad de esos datos.	• Evalúe los procedimientos documentados. • Evalúe los registros en medios u otra documentación.	☐	☐	☐	☐
9.4.3	Los apoyos con datos de tarjetahabiente enviados fuera de las instalaciones se protegen de la siguiente manera: • *Punto dejado en blanco intencionadamente para este SAQ.* • Los datos se envían por mensajería segura u otro método de entrega que pueda ser rastreado con precisión. • *Punto dejado en blanco intencionadamente para este SAQ.*	• Evalúe los procedimientos documentados. • Entreviste al personal. • Evalúe los registros. • Evalúe los registros de seguimiento externo de todos los medios.	☐	☐	☐	☐
9.4.4	La gerencia aprueba todos los movimientos de respaldos con datos de tarjetahabiente que se trasladan fuera de las instalaciones (incluso cuando son distribuidos a particulares).	• Evalúe los procedimientos documentados. • Evalúe los registros de seguimiento externo. • Entreviste al personal responsable.	☐	☐	☐	☐
	Notas de Aplicabilidad Las personas que aprueban los movimientos de los apoyos deben tener el nivel adecuado de autoridad de gestión para conceder esta aprobación. Sin embargo, no se requiere específicamente que dichas personas tengan el título de "gerente".					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
9.4.6	Los materiales impresos con datos de tarjetahabiente se destruyen cuando ya no se necesitan por razones de negocios o legales, de la siguiente manera: • Los materiales se trituran transversalmente, se incineran o se pulverizan de forma que los datos de tarjetahabiente no puedan reconstruirse. • Los materiales se guardan en contenedores de almacenamiento seguro antes de su destrucción.	• Evalúe la política de destrucción de medios. • Observe los procesos. • Entreviste al personal. • Observe los contenedores de almacenamiento.	☐	☐	☐	☐
	Notas de Aplicabilidad Estos requisitos relativos a la destrucción de materiales impresos cuando éstos ya no son necesarios por motivos de negocio o legales son independientes y distintos del requisito 3.2.1 PCI DSS, que se refiere a la eliminación segura de los datos de tarjetahabiente cuando ya no son necesarios de acuerdo con las políticas de retención de datos de tarjetahabiente de la entidad.					

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para los Requisitos de la sección 9.4 significa que el comerciante almacena de forma segura cualquier soporte de papel con datos del titular de la tarjeta, por ejemplo, guardando el papel en un cajón, armario o caja fuerte cerrados con llave, y que el comerciante destruye dicho papel cuando ya no lo necesita para fines de negocios. Esto incluye un documento escrito o una política para los empleados, de manera que ellos sepan cómo proteger el papel con los datos del titular de la tarjeta y cómo destruir el papel cuando ya no lo necesiten.

Si el comerciante nunca imprime ni almacena ningún papel que contenga datos del titular de la tarjeta, marque este requisito como No aplicable y llene el Anexo C: Explicación de los Requisitos Señalados como No Aplicable.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
9.5 Los dispositivos de Punto de Interacción (POI) están protegidos contra manipulaciones y sustituciones no autorizadas.						
9.5.1	Los dispositivos POI que capturan los datos de las tarjetas de pago a través de la interacción física directa con el factor de forma de la tarjeta de pago están protegidos contra la manipulación y la sustitución no autorizada, incluyendo lo siguiente: • Mantener una lista de dispositivos de POI. • Inspeccionar periódicamente los dispositivos de POI en busca de manipulaciones o sustituciones no autorizadas. • Formar al personal para que esté atento a los comportamientos sospechosos y denuncie las manipulaciones o sustituciones no autorizadas de los dispositivos.	• Evalúe las políticas y procedimientos documentados.	☐	☐	☐	☐
	Notas de Aplicabilidad Estos requisitos se aplican a los dispositivos de POI desplegados que se utilizan en transacciones con tarjeta física (es decir, un factor de forma de tarjeta de pago como una tarjeta que se pasa, se toca o se introduce). Estos requisitos no se aplican a: • Componentes utilizados únicamente para la introducción manual de claves PAN. • Dispositivos comerciales listos para usar (*commercial off-the-shelf*, COTS) (por ejemplo, teléfonos inteligentes o tabletas), que son dispositivos móviles propiedad del comerciante diseñados para la distribución masiva.					
9.5.1.1	Se mantiene una lista actualizada de los dispositivos POI, que incluye: • Marca y modelo del dispositivo. • Ubicación del dispositivo. • Número de serie del dispositivo u otros métodos de identificación única.	• Evalúe la lista de dispositivos POI. • Observe los dispositivos POI y la ubicación de los dispositivos. • Entreviste al personal.	☐	☐	☐	☐
9.5.1.2	Las superficies de los dispositivos POI se inspeccionan periódicamente para detectar manipulaciones y sustituciones no autorizadas.	• Evalúe los procedimientos documentados. • Entreviste al personal responsable. • Observe los procesos de inspección.	☐	☐	☐	☐

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
9.5.1.2.1	*Requisito dejado en blanco intencionadamente para este SAQ.*					
9.5.1.3	Se proporciona capacitación para que el personal en entornos de POI esté al tanto de los intentos de manipulación o reemplazo de dispositivos POI, lo que incluye: • Verificar la identidad de cualquier tercero que afirme ser personal de reparación o mantenimiento, antes de otorgarles acceso para modificar o solucionar problemas en los dispositivos. • Procedimientos para garantizar que los dispositivos no se instalen, reemplacen o devuelvan sin verificación. • Ser consciente de comportamientos sospechosos alrededor de los dispositivos. • Informar sobre comportamientos sospechosos e indicaciones de manipulación o sustitución de dispositivos al personal apropiado.	• Revisar los materiales de capacitación del personal en entornos POI. • Entreviste al personal responsable.	☐	☐	☐	☐

Guía para llenar el SAQ:

Seleccionar cualquier respuesta "Implementado" para los Requisitos de la sección 9.5 significa que el comerciante dispone de políticas y procedimientos implementados para los Requisitos 9.5.1, 9.5.1.1, 9.5.1.2 y 9.5.1.3, y que mantiene una lista actualizada de dispositivos, realiza inspecciones periódicas de los mismos y capacita a los empleados sobre lo que deben buscar para detectar o dispositivos manipulados o sustituidos.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Monitorear y Verificar las Redes Regularmente

Requisito 11: Poner a Prueba Regularmente la Seguridad de los Sistemas y de las Redes

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
11.3 Las vulnerabilidades externas e internas se identifican, se priorizan y se abordan periódicamente.						
11.3.2	Los escaneos de vulnerabilidad externos se realizan de la siguiente manera: • Al menos una vez cada tres meses. • Por parte de un proveedor de Escaneo Aprobado por PCI SSC (ASV). • Las vulnerabilidades se resuelven y se cumple con los requisitos de la *Guía del Programa ASV.* • Se realizan nuevos escaneos según sea necesario para confirmar que las vulnerabilidades se han resuelto de acuerdo con los requisitos de la Guía del Programa ASV escaneos aprobados. *(continuación)*	• Evalúe los reportes de escaneos ASV.	☐	☐	☐	☐

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS	Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
		Implementado	Implementado con CCW	No Aplicable	No Implementado
Notas de Aplicabilidad					
Para el cumplimiento inicial PCI DSS con respecto a este requisito, no es necesario que se completen cuatro escaneos aprobados en un plazo de 12 meses si el asesor verifica que: 1) el resultado del escaneo más reciente fue un escaneo satisfactorio, 2) la entidad ha documentado políticas y procedimientos que requieren escaneos al menos una vez cada tres meses, y 3) las vulnerabilidades observadas en los resultados del escaneo se han corregido como se muestra en un re-escaneo. Sin embargo, durante los años siguientes después de la evaluación inicial PCI DSS, deben haberse realizado escaneos aprobados al menos cada tres meses. Las herramientas de escaneo de ASV pueden escanear una amplia gama de tipos y topologías de redes. Cualquier detalle sobre el entorno de destino (por ejemplo, distribuidores de carga, proveedores externos, ISP, configuraciones específicas, protocolos en uso, interferencia de escaneo) debe resolverse entre el ASV y el cliente de escaneo. Consulte la *Guía del Programa ASV* publicada en el sitio web de PCI SSC para conocer las responsabilidades del cliente de escaneo, la preparación del escaneo, etc.					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
11.4 Las pruebas de penetración externas e internas se realizan con regularidad y se corrigen las vulnerabilidades explotables y las debilidades de seguridad.						
11.4.5	Si la segmentación se utiliza para aislar el CDE de otras redes, las pruebas de penetración se realizan en los controles de segmentación de la siguiente manera: • Al menos una vez cada 12 meses y después de cualquier cambio en los controles/métodos de segmentación. • Cubriendo todos los controles/métodos de segmentación en uso. • *Punto dejado en blanco intencionadamente para este SAQ.* • Confirmar que los controles/métodos de segmentación son operativos y eficientes, y aislar al CDE de todos los sistemas fuera del ámbito. • Confirmar la efectividad de cualquier uso de aislamiento para separar sistemas con diferentes niveles de seguridad (ver Requisito 2.2.3). • Realizado por un recurso interno calificado o un tercero externo calificado. • El asesor cuenta con independencia organizacional (no se requiere que sea un QSA o ASV).	• Evalúe los controles de segmentación. • Revise la metodología de penetración-prueba. • Evalúe los resultados de la prueba de penetración más reciente. • Entreviste al personal responsable.	☐	☐	☐	☐

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Mantener una Política de Seguridad de la Información

Requisito 12: Respaldar la Seguridad de la Información con Políticas y Programas Organizacionales

Nota: *El Requisito 12 especifica que los comerciantes tengan políticas de seguridad de la información para su personal, pero estas políticas pueden ser tan simples o complejas como sea necesario para el tamaño y la complejidad de las operaciones del comerciante. El documento con las políticas debe entregarse a todo el personal para que sean conscientes de sus responsabilidades a la hora de proteger los terminales de pago, cualquier documento en papel con datos del titular de la tarjeta, etc. Si un comerciante no tiene empleados, se espera que el comerciante entienda y reconozca su responsabilidad con la seguridad dentro de sus tiendas.*

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.1 Una política integral de seguridad de la información que rija y proporcione orientación para la protección de los activos de información de la entidad es actualizada y bien conocida.						
12.1.1	Una política general de seguridad informática es: • Establecida. • Publicada. • Mantenida. • Difundida a todo el personal relevante, así como a los proveedores y socios de negocios relevantes.	• Evalúe la política de protección informática. • Entreviste al personal.	☐	☐	☐	☐
12.1.2	La política de seguridad de la información es: • Revisada al menos una vez cada 12 meses. • Actualizada según sea necesario para reflejar los cambios en los objetivos de negocios o en los riesgos para el entorno.	• Evalúe la política de protección informática. • Entreviste al personal responsable.	☐	☐	☐	☐

Guía para llenar el SAQ:

La selección de cualquiera de las respuestas Implementado para los Requisitos 12.1.1 y 12.1.2 significa que el comerciante tiene una política de seguridad que es razonable para el tamaño y la complejidad de sus operaciones, y que la política se revisa al menos una vez cada 12 meses y se actualiza si es necesario.

Por ejemplo, dicha política podría ser un documento sencillo que cubra cómo proteger la tienda y los dispositivos de pago de acuerdo con el manual de orientación/instrucciones del proveedor de la solución, y a quién llamar en caso de emergencia.

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.1.3	La política de seguridad define claramente los roles y responsabilidades de seguridad informática para todo el personal, y todo el personal conoce y reconoce sus responsabilidades en materia de protección informática.	• Evalúe la política de protección informática. • Entreviste al personal responsable. • Evalúe las evidencias documentadas.	☐	☐	☐	☐
Guía para llenar el SAQ: *La selección de cualquiera de las respuestas Implementado para el Requisito 12.1.3 significa que la política de seguridad del comerciante define las responsabilidades básicas de seguridad para todo el personal, en consonancia con el tamaño y la complejidad de las operaciones el comerciante. Por ejemplo, las responsabilidades de seguridad podrían definirse según las responsabilidades básicas por niveles de empleados, como las responsabilidades que se esperan de un gerente/propietario y las que se esperan de los oficinistas.*						
12.6 La educación en concienciación sobre la seguridad es una actividad continua.						
12.6.1	Se implementa un programa formal de concientización sobre seguridad para que todo el personal conozca la política y los procedimientos de seguridad de la información a de la entidad, y el rol del personal en la protección de los datos de tarjetahabiente.	• Evalúe el programa de concienciación sobre seguridad.	☐	☐	☐	☐
Guía para llenar el SAQ: *La selección de cualquiera de las respuestas Implementado para el Requisito 12.6.1 significa que el comerciante tiene un programa de concienciación sobre seguridad establecido en consonancia con el tamaño y la complejidad de las operaciones del comerciante. Por ejemplo, un simple programa de concienciación podría ser un folleto publicado en la oficina o un correo electrónico periódico enviado a todos los empleados. Entre los ejemplos de mensajes del programa de concienciación se incluyen descripciones de los consejos de seguridad que deben seguir todos los empleados, como la forma de cerrar las puertas y los contenedores de almacenamiento, cómo determinar si una terminal de pago ha sido manipulada, y los procesos para confirmar la identificación y verificar que existe una razón de negocios legítima para cualquier empleado cuando utilizan las terminales de pago.*						

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.8 Gestión del riesgo de los activos de información asociados a las relaciones con proveedores de servicios externos (TPSP).						
12.8.1	Se mantiene una lista de todos los proveedores de servicios de terceros (TPSP) con los que se comparten los datos del titular de la tarjeta o que podrían afectar a la seguridad de los datos del titular de la tarjeta, incluyendo una descripción para cada uno de los servicios prestados.	• Evalúe las políticas y procedimientos. • Evalúe la lista de TPSP.	☐	☐	☐	☐
	Notas de Aplicabilidad El uso de un TPSP que cumpla con PCI DSS no hace que una entidad esté en conformidad con PCI DSS, ni elimina la responsabilidad de la entidad por su propia conformidad con PCI DSS.					
12.8.2	Se mantienen acuerdos escritos con los TPSP de la siguiente manera: • Se mantienen acuerdos escritos con todos los TPSP con los que se comparten datos del titular de la tarjeta o que podrían afectar la seguridad del CDE. • Los acuerdos escritos incluyen el reconocimiento por parte de los TPSP de que los TPSP son responsables por la seguridad de los datos del titular de la tarjeta que los TPSP poseen o almacenan, procesan o transmiten en nombre de la entidad, o en la medida en que puedan afectar a la seguridad de los datos tarjetahabiente o datos de autenticación sensibles de la entidad. *(continuación)*	• Evalúe las políticas y procedimientos. • Evalúe los acuerdos escritos con los TPSP.	☐	☐	☐	☐

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
	Notas de Aplicabilidad La redacción exacta de un acuerdo dependerá de los detalles del servicio que se esté proporcionando y de las responsabilidades asignadas a cada parte. El acuerdo no tiene que incluir la redacción exacta proporcionado en este requisito. El reconocimiento por escrito del TPSP es una confirmación que establece que el TPSP es responsable de la seguridad de los datos de cuenta que pueda almacenar, procesar o transmitir en nombre del cliente o en la medida en que el TPSP pueda afectar la seguridad de los datos tarjetahabiente o datos de autenticación sensibles La evidencia de que un TPSP cumple con los requisitos de PCI DSS no es lo mismo que el reconocimiento por escrito especificado en este requisito. Por ejemplo, una Certificación de Cumplimiento (AOC) de PCI DSS, una declaración en el sitio web de una empresa, una declaración de políticas, una matriz de responsabilidades u otra evidencia que no esté incluida en un acuerdo escrito no es un reconocimiento por escrito.					
12.8.3	Se implementa un proceso establecido para contratar a los TPSP, incluyendo la debida diligencia antes de la contratación.	• Evalúe las políticas y procedimientos. • Evalúe la evidencia. • Entreviste al personal responsable.	☐	☐	☐	☐
12.8.4	Se implementa un programa para monitorear el estado de conformidad PCI DSS de los TPSP al menos una vez cada 12 meses.	• Evalúe las políticas y procedimientos. • Evalúe la documentación • Entreviste al personal responsable.	☐	☐	☐	☐
	Notas de Aplicabilidad Cuando una entidad tiene un acuerdo con un TPSP para cumplir con los requisitos de PCI DSS en nombre de la entidad (por ejemplo, a través de un servicio de firewall), la entidad debe trabajar con el TPSP para asegurarse de que se cumplan los Requisitos de PCI DSS aplicables. Si el TPSP no cumple con los Requisitos de PCI DSS aplicables, entonces, esos requisitos también están “no implementado” para la entidad.					

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (Marque una respuesta para cada requisito)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
12.8.5	Se mantiene información sobre qué requisitos de PCI DSS gestiona cada TPSP, cuáles gestiona la entidad y cualquiera que se comparta entre el TPSP y la entidad.	• Evalúe las políticas y procedimientos. • Evalúe la documentación • Entreviste al personal responsable.	☐	☐	☐	☐
Guía para llenar el SAQ: *La selección de cualquiera de las respuestas Implementado para los requisitos de 12.8.1 a 12.8.5 significa que el comerciante tiene una lista de proveedores de servicios con los que comparte datos del titular de la tarjeta y tiene acuerdos con ellos, o que podrían afectar a la seguridad del entorno de datos de tarjetahabiente del comerciante. Por ejemplo, estos acuerdos serían aplicables si un comerciante utiliza un proveedor de conservación de documentos para almacenar documentos en papel que incluyan datos del titular de la tarjeta o si un proveedor del comerciante ingresa a los sistemas del comerciante de forma remota para realizar un mantenimiento.*						
12.10 Respuesta inmediata a incidentes de seguridad sospechosos y confirmados que podrían afectar al CDE.						
12.10.1	Existe un plan de respuesta a incidentes y está listo para activarse en caso de sospecha o confirmación de un incidente de seguridad.	• Evalúe el plan de respuesta a incidentes. • Entreviste al personal. • Evalúe la documentación de los incidentes reportados anteriormente.	☐	☐	☐	☐
Guía para llenar el SAQ: *La selección de cualquiera de las respuestas Implementado para el Requisito 12.10.1 significa que el comerciante tiene un plan documentado de respuesta a incidencias y escalada que puede usarse para emergencias, y que es coherente el tamaño y la complejidad de las operaciones del comerciante. Por ejemplo, un plan de este tipo podría ser un simple documento colgado en la oficina que enumere a quién llamar en caso de diversas situaciones, con una revisión anual para confirmar que sigue siendo preciso, pero podría extenderse hasta un plan completo de respuesta a incidentes que incluya instalaciones de reserva "hotsite" y pruebas anuales exhaustivas. Este plan debe estar a disposición de todo el personal como recurso en caso de emergencia.*						

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo A: Requisitos Adicionales de PCI DSS

Anexo A1: Requisitos Adicionales de PCI DSS para Proveedores de Servicios Multiusuario

Este Anexo no se utiliza para las evaluaciones comerciales.

Anexo A2: Requisitos Adicionales de PCI DSS Para Entidades que Utilizan SSL / Primeras versiones de TLS para Conexiones de Terminal POS POI Presencial con Tarjetas

Requisito de PCI DSS		Pruebas Previstas	Respuesta♦ (*Marque una respuesta para cada requisito*)			
			Implementado	Implementado con CCW	No Aplicable	No Implementado
A2.1 Los terminales POI que utilizan SSL y/o TLS inicial no son susceptibles a vulnerabilidades conocidas de SSL/TLS.						
A2.1.1	Cuando los terminales POS POI del comerciante o en la ubicación de aceptación de pagos usan SSL y/o TLS inicial, la entidad confirma que los dispositivos no son susceptibles a ninguna vulnerabilidad conocida para esos protocolos.	• Evalúe la documentación (por ejemplo, documentación del proveedor, detalles de la configuración del sistema o de la red) que verifica que los dispositivos no son susceptibles a vulnerabilidades conocidas para SSL/TLS inicial.	☐	☐	☐	☐
	Notas de Aplicabilidad Este requisito está destinado a aplicarse a la entidad con el terminal POS POI, como un comerciante. Este requisito no está destinado a los proveedores de servicios que sirven como punto de terminación o conexión a esos terminales POS POI. Los Requisitos A2.1.2 y A2.1.3 se aplican a los proveedores de servicios POS POI e intencionalmente no se incluyen este SAQ. La asignación para terminales POS POI que actualmente no son susceptibles a vulnerabilidades se basa en los riesgos actualmente conocidos. Si se introducen nuevas vulnerabilidades a las que los terminales POS POI son susceptibles, estas deberán actualizarse inmediatamente.					

♦ *Consulte la sección "Respuestas a los Requisitos" (página vi) para obtener información sobre estas opciones de respuesta.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo A3: Validación Complementaria de Entidades Designadas (DESV)

Este Anexo se aplica solo a las entidades designadas por una marca de pago o adquirente que requieren una validación adicional de los Requisitos de PCI DSS vigentes. Las entidades que deban validar este Anexo deben utilizar la Plantilla de Informes Complementarios DESV y la Certificación de Conformidad Complementaria para la presentación de informes y consultar con la marca de pago y/o el adquirente correspondiente para los procedimientos de presentación.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo B: Ficha de Control Compensatorio

Este Anexo debe llenarse para definir los controles compensatorios cualquier requisito en el que se haya seleccionado Implementado con CCW.

Nota: *Sólo las entidades que tengan limitaciones tecnológicas o comerciales legítimas y documentadas pueden considerar el uso de controles compensatorios para lograr la conformidad.*

Refiérase a los Anexos B y C del PCI DSS para más información acerca de los controles compensatorios y orientación sobre cómo llenar esta hoja.

Número de Requisito y Definición:

	Información Requerida	Explicación
1. Restricciones	Documente las limitaciones técnicas o comerciales legítimas que impiden la conformidad con el requisito original.	
2. Definición de los Controles Compensatorios	Defina los controles compensatorios: explique cómo abordan los objetivos del control original y el aumento del riesgo si lo hay.	
3. Objetivo	Defina el objetivo del control original.	
	Identifique el objetivo que cumple el control compensatorio. ***Nota:*** *Este puede ser, pero no es obligatorio, el Objetivo del Enfoque Personalizado establecido para este requisito en PCI DSS.*	
4. Riesgo Identificado	Identifique cualquier riesgo adicional que suponga la falta del control original.	
5. Validación de los Controles Compensatorios	Defina cómo se validaron y comprobaron los controles compensatorios.	
6. Mantenimiento	Defina los procesos y controles establecidos para mantener los controles compensatorios.	

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo C: Explicación de los Requisitos Señalados como No Aplicable

Este Anexo debe llenarse para cada requisito en el que se haya seleccionado No Aplicable

Requisito	Razón por la cual el Requisito es No Aplicable
Ejemplo:	
Requisito 3.5.1	*Los datos del titular de la tarjeta nunca se almacenan electrónicamente*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Anexo D: Explicación de los Requisitos Señalados como No Probado

Este Anexo no se utiliza para las evaluaciones de comerciantes SAQ B-IP.

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Sección 3: Detalles de Validación y Certificación

Parte 3. Validación PCI DSS

Esta AOC se basa en los resultados anotados en el SAQ B-IP (Sección 2), fechados (Fecha de finalización de la autoevaluación *DD-MM-AAAA*).

Sobre la base de los resultados documentados en el SAQ B-IP indicado anteriormente, cada firmante identificado en cualquiera de las Partes 3b-3d, según corresponda, afirma el siguiente estado de conformidad para el comerciante identificado en la Parte 2 de este documento.

Seleccione uno:

☐	**En Conformidad:** Todas las secciones del PCI DSS SAQ están completas y todos los requisitos están marcados como 1) Implementado 2) Implementado con CCW, o 3) No Aplicable, lo que resulta en una calificación general de **EN CONFORMIDAD**; por lo tanto *(Nombre del Comerciante)* ha demostrado estar en conformidad con todos los Requisitos de PCI DSS incluidos en este SAQ.
☐	**No Conformidad:** No se han completado todas las secciones del PCI DSS SAQ, o uno, o más requisitos están marcados como No implementados, lo que resulta en una calificación general de **NO CONFORMIDAD**, por lo tanto *(Nombre del Comerciante)* no ha demostrado estar en conformidad con los Requisitos de PCI DSS incluidos en este SAQ. **Fecha Límite** para estar en Conformidad: *DD-MM-AAAA* El comerciante que envíe este formulario mostrando un estado de No-Conformidad podría tener que proveer un Plan de Acción en la Parte 4 de este documento. Confirme con la entidad a la que se presentará este AOC antes de completar la Parte 4.
☐	**Conforme pero con una excepción legal:** Uno o más de los requisitos evaluados en el PCI DSS SAQ están marcados como No Implementados debido a una restricción legal que impide que se cumpla con el requisito y todos los demás requisitos están marcados como 1) Implementado, 2) Implementado con CCW, o 3) No Aplicable, lo que da como resultado una calificación general de **EN CONFORMIDAD PERO CON EXCEPCIÓN LEGAL;** por lo tanto, *(Nombre del Comerciante)* ha demostrado estar en conformidad con todos los Requisitos de PCI DSS incluidos en este SAQ, excepto los señalados como No Implementados debido a una restricción legal. Esta opción requiere una revisión adicional por parte de la entidad a la que se presentará este AOC. *Si la selecciona, complete lo siguiente:*

Requisito Concerniente	Detalles de cómo la restricción legal impide que se cumpla con el requisito

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 3a. Reconocimiento del Comerciante

El signatario confirma:

(Seleccione todos lo que aplican)

☐	El Cuestionario de Autoevaluación PCI DSS B-IP, Versión 4.0.1, ha sido completado de acuerdo con las instrucciones que en el figuran.
☐	Toda la información contenida en el cuestionario de autoevaluación SAQ y en esta declaración representan fielmente los resultados de la evaluación del comerciante en todos los aspectos materiales.
☐	Los controles PCI DSS se mantendrán en todo momento, según corresponda al entorno del comerciante.

Parte 3b. Declaración del Comerciante

Firma del Ejecutivo del Comerciante ↑	*Fecha: DD-MM-AAAA*
Nombre del Ejecutivo del Comerciante:	*Título:*

Parte 3c. Declaración del Asesor de Seguridad Calificado (QSA)

Si un QSA ha participado o asistido en esta evaluación, indique la función que desempeñó:	☐ El QSA realizó los procedimientos de prueba.
	☐ El QSA prestó otro tipo de asistencia. Si ha seleccionado, describa todas las funciones desempeñadas:

Firma del QSA principal ↑	*Fecha: DD-MM-AAAA*
Nombre del QSA principal:	

Firma del Funcionario Debidamente Autorizado de la Compañía QSA ↑	*Fecha: DD-MM-AAAA*
Nombre del Funcionario Debidamente Autorizado:	*Compañía QSA:*

Parte 3d. Participación del Asesor de Seguridad interna (ISA) del PCI SSC

Si un ISA ha participado o ha prestado asistencia en esta Evaluación, indique la función desempeñada:	☐ El ISA(s) realizó los procedimientos de prueba.
	☐ El ISA(s) prestó otro tipo de asistencia. Si ha seleccionado, describa todas las funciones desempeñadas:

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Parte 4. Plan de Acción para Requisitos de No-Conformidad

Sólo complete la Parte 4 si es solicitado por la entidad a la que se va a presentar este AOC, y sólo si la Evaluación presenta resultados de No-Conformidad señalados en la Sección 3.

Si se le pide que rellene esta sección, seleccione la respuesta apropiada para "En Conformidad con los Requisitos de PCI DSS" para cada uno de los requisitos siguientes. Para cualquier respuesta "No", incluya la fecha en la que el comerciante espera poder estar en conformidad con el requisito y una breve descripción de las medidas que se están implementando para estar en conformidad.

Requisito de PCI DSS*	Descripción del Requisito	En Conformidad con los Requisitos de PCI DSS (Seleccione Uno)		Rehabilitación Fecha y Acciones (Si selecciona "NO" para cualquier Requisito)
		SÍ	NO	
1	Instalar y mantener los controles de seguridad de la red	☐	☐	
2	Aplicar configuraciones seguras a todos los componentes del sistema	☐	☐	
3	Proteger los datos del titular de la tarjeta almacenados	☐	☐	
4	Proteger los datos de tarjetahabiente con criptografía robusta durante la transmisión a través de redes abiertas y públicas	☐	☐	
6	Desarrollar y mantener sistemas y softwares seguros	☐	☐	
7	Restringir el acceso a los componentes del sistema y a los datos de tarjetahabiente según la necesidad de conocimiento de la empresa	☐	☐	
8	Identificar a los usuarios y autenticar el acceso a los componentes del sistema	☐	☐	
9	Restringir el acceso físico a los datos de tarjetahabiente	☐	☐	
11	Poner a prueba regularmente la seguridad de los sistemas y de las redes	☐	☐	
12	Respaldar la seguridad de la información con políticas y programas organizacionales	☐	☐	
Anexo A2	Requisitos adicionales de PCI DSS para entidades que utilizan SSL/primeras versiones de TLS para conexiones de terminal POS POI presencial con tarjetas	☐	☐	

** Los Requisitos de PCI DSS indicados anteriormente se refieren a los requisitos de la Sección 2 de este SAQ.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.

Nota: *El PCI Security Standards Council es un organismo de normas global que proporciona recursos para profesionales de la seguridad de los pagos que son desarrollados en colaboración con nuestra comunidad de partes interesadas. Nuestros materiales son aceptados en numerosos programas de cumplimiento en todo el mundo. Consulte con su organización de cumplimiento individual para asegurarse de que este formulario sea aceptado en su programa. Para obtener más información sobre PCI SSC y nuestra comunidad de partes interesadas, visite: https://www.pcisecuritystandards.org/about_us/.*

© 2006-2024 PCI Security Standards Council, LLC. Todos los Derechos Reservados.